

Sri Lanka Institute of Information Technology



Enterprise Standards for Information Security - IE3102

Business Process Document

IT23269484 – T. H. Ranasinghe

1. Introduction

In today's digital age, data is one of the most important assets a company can have. The proliferation of data driven systems, cloud computing and internet have critically increased exposure to cyber-threats, data breaches and unauthorized access. Managing sensitive data is accordingly both strategic and operational priority number one for every organization, big or small.

The ISO/IEC 27001:2022 standard is an internationally recognized framework that helps organizations to design, implement, maintain and continually improve a Information Security Management System (ISMS). It allows organizations to pinpoint conceivable security threats, develop strong control structures, and guarantee that information assets are protected according to their significance.

This Business Process Document outlines an organization-agnostic process model to support the implementation of ISO 27001. It defines a process for setting up, operating, monitoring, reviewing and improving an ISMS. The approach utilizes PDCA (Plan–Do–Check–Act) cycle and risk-based thinking and is in line with the demands of Clauses 4 to 10 of that standard.

This document is designed to be used as part of a suite of ISO 27001 Implementation Toolkit, helping consultants, managers and implementers work in a more robust manner towards certification and long-term resilience for their information security.

2. ISO 27001 Implementation Model

IT is like PDCA (Plan–Do–Check–Act), the ISO 27001 standard. This model focuses on a cycle of planning, doing, reviewing and acting to ensure that the ISMS remains effective and aligns with the needs of the organization.

Phase	Purpose	Key Deliverables
Plan	Determine the scope, context, risk appetite and objectives of the ISMS.	ISMS Policy, Risk Register, SoA.
Do	Apply chosen security controls and risk handling measures.	Operating procedures, training program, evidence of control deployment.
Check	Test Performance, Conduct Real Audits and Measures	KPI dashboard, Internal Audit Report and Management Review results.
Act	Ensure nonconformities get treated and enhance the ISMS.	plan and correct the corrective action plans and revised risk treatment strategies.

This is a feedback-driven system to keep the ISMS active, flexible toward new threats, and constantly in sync with business objectives.

3. Defining the Scope and Context

3.1 Organizational Context

Reference 4: ISO 27001 clause 4 ISO 27001, clause 4 is about understanding all of the related internal and external issues that impact on your information security management system.

Internal context includes:

- Structure, roles and governance architecture of the organization.
- Existing IT infrastructure and resources.
- Security culture and employee competence.
- As a result, the following business processes and flow of information now exist.

External context involves:

- Legal, Regulatory and Compliance requirements (e.g., data protection laws [like GDPR] etc.)
- Trends of the market, preferences of customers and competition.
- Technology development and cyber security threat landscape.

Having this background can also help to define ISMS priorities and to ensure that the system adopted remains in-line and proportionate with the organization's actual risk exposure.

3.2 ISMS Scope Definition

The boundaries and the extent of application of the ISMS are specified in scope. It specifies what systems, assets, and information are covered by the policy.

Components of a clear scope are as follow:

- Durable lines of demarcation: offices, data centers, remote facilities and cloud services.
- Processes included: HR, finance, IT service delivery and customer data processing.
- Assets of information: such as computers, software, records and intellectual property assets.
- Parties involved: employees, customers, suppliers, authorities and auditors.

Example Scope Statement:

“The ISMS encompasses all systems and information assets that support the storing, processing and transmission of customer and employee data at corporate offices; cloud hosting environments; and disaster recovery facilities.”

A well-defined, agreed and documented scope will ensure that ISMS activities aren't spent on things you didn't mean or want them to be.

4. Risk Assessment and Treatment Process

The ISO 27001 standard is based on a risk-centric approach and makes sure that security decisions are based on real business risks, in contrast with assumptions.

4.1 Risk Identification

Risk identification of information security is paramount for organizations as they should approach systematically. Sources include:

- **External threats:** cyber threats like attacks, malware, phishing or DDoS.
- **Internal threats:** employee or contractor misuse, exfiltration of the data by an admin, or misconfiguration.
- **Environmental factors:** loss of power, natural disaster or hardware failure.

For example, Asset Register would identify significant information assets, their owners and possible threats and vulnerabilities.

4.2 Risk Analysis and Evaluation

Each potential risk needs to be assessed for probability and impact. This assessment is often performed with a 5×5 matrix:

Likelihood	Impact	Risk Score	Risk Level
1–2	1–2	1–4	Low
3	3	9	Medium
4–5	4–5	16–25	High

High risk (≥ 15) situations require immediate action, while medium risks are reduced by cost-effective measures.

Residual risk must also be reviewed after considering controls and approved by management.

4.3 Risk Treatment

Per ISO 27001 Clause 6.1.3, companies are to develop and document controls for each risk with the RTP.

Treatment options include:

- **Avoid** – remove the activity which places you at risk.
- **Transfer** – move or share the risk.
- **Reduce / Mitigate** – Logically use technical or administrative controls.
- **Accept** – recognize low-priority risks are within acceptable limits.

The SoA lists all chosen controls from Annex A and explains if they have been included or excluded.

4.4 Integration with ISO 31000

Integration of the ISO 27001 risk management approach into the ISO 31000:2018 Risk Management guidance provides systematic governance, accountability and stakeholder communication across the life cycle of risk.

5. Establishing Security Controls

ISO/IEC 27001:2022 update consists of 93 controls, divided into a simplified four-phase structure:

Domain	Purpose	Examples of Controls
Organizational	Establish security governance and policies.	Information classification, supplier management, business continuity policy.
People	Manage human-related risks.	Employee background checks, awareness programs, access authorization.
Physical	Protect physical environments.	Secure areas, entry controls, visitor logs, asset disposal.
Technological	Safeguard IT systems and data.	Encryption, MFA, intrusion detection, patch management, backup verification.

The implementation of controls varies for each organization and must be customized to the unique setting of an organization, which includes recording evidence such as system configurations, training attendance or policy approval.

6. Implementation and Operation

The “Do” phase transforms planning into action. Introducing ISMS requires the introduction of technology, processes and people.

6.1 Policy and Procedure Development

Develop and approve key ISMS documents:

- Information Security Policy.
- Access Control Policy.
- Incident Response Procedure.
- Business Continuity and Disaster Recovery Plan.

These documents form the operational backbone of the ISMS.

6.2 Roles and Responsibilities

Assign clearly defined roles:

- **ISMS Manager** : oversees overall implementation.
- **Risk Owner** : a responsible for effectiveness of risk control.
- **Internal Auditor** : ensures compliance verification.
- **Employees** : obey policies and report any incidents.

6.3 Technical and Organizational Implementation

- Use encryption, anti-malware and other protective tools.
- Set up firewalls, access control, and backups.
- Segregation of duties and least privilege principles are born in mind.
- Conduct awareness and role-based training.

It is required that the actions taken be documented and auditable according to the predefined activities.

7. Monitoring, Evaluation, and Internal Audit

Clause 9 of ISO 27001 is all about monitoring, measurement, analysis and evaluation as measurement of performance statement.

7.1 Performance Monitoring

The Key Performance Indicators (KPIs) that show how KMS is effective are :

- Decrease in security incidents per quarter.
- Average incident response time.
- Proportion of controls confirmed effective.
- Employee training completion rate.

Dashboards provided by automation or SIEM tools can facilitate evidence-based performance analysis.

7.2 Internal Audits

Internal reviews prove that the ISMS fits both ISO 27001, as well as internal processes.

The audit cycle is generally annually with some firms having semi-annual coverage based on risk. Findings are categorized as:

- **Major Nonconformity** - Inability to effectively establish or adhere to a required measure.
- **Minor Nonconformity:** partial breach of policy.
- **Observation:** improvement opportunity.

Corrective measures are recorded and tracked to closure.

7.3 Management Review

Senior management reviews the performance of the ISMS at planned intervals to verify its continuing adequacy and effectiveness. Reviews typically assess:

- Audit results and KPI trends.
- Risk register updates.
- Nonconformities and corrective actions.
- External or internal (new rules, mergers).

Outputs are decisions regarding betterment, deployment of resources, and policy revision.

8. Continual Improvement

Clause 10 of ISO 27001 requires the ISMS to be updated on a regular basis. It is important to have a system in place that deals with nonconformance, takes corrective action and promotes new ideas.

8.1 Corrective and Preventive Actions

When problems occur, root cause analysis can be used to identify preventative action. There is a log of all activity and follow-up to determine effectiveness.

8.2 Learning and Adaptation

Audit feedback, incidents and information shared by employees is used to improve processes, document changes and build organizational resilience.

8.3 Technological and Regulatory Adaptation

To improve without end is also to be open to:

- New cybersecurity technologies.
- Emerging threats and vulnerabilities.
- Changing legal or compliance requirements.

9. Challenges and Mitigation Strategies

Challenge	Description	Mitigation Strategy
Limited Management Support	ISMS initiatives frequently do not receive money or attention without the leadership on board.	Get executive sponsorship and s/t measurable ROI.
Lack of Expertise	Organizations may be new to ISO 27001.	Hire certified consultants and train your employees.
Cultural Resistance	The controls are portrayed as oppressive by staff.	Promote awareness campaigns that focus on individual responsibility.
Resource Constraints	Implementation is deferred by lack of budget or time.	Implement in phases and focus on highly risky regions.
Documentation Overload	Excessive paperwork can slow progress.	Employ the use of templates and digital Document Management Systems.

10. Expected Benefits

The use of ISO/IEC 27001:2022 carries several benefits in many different ways, tangible as well as intangible:

- **Improved Compliance:** comply with worldwide data protection and privacy regulations.
- **Productivity:** makes the operation and management of security easier.
- **Customer Trust:** shows reliability and sense of responsibility.
- **Incident Prevention:** reduces the number and scope of incidents.
- **Business Continuity:** establishes the capability to withstand interruptions.
- **Unique Selling Proposition:** the point of difference saving time in proposal writing and sourcing agreements.
- **Enhanced Culture:** Encourages widespread security responsibility throughout staff.

11. Conclusion

In short, implementing an ISMS in accordance with ISO/IEC 27001:2022 involves much more than just technical compliance – it's a business strategy that helps the organization govern and protect itself.

By adhering to the PDCA model, business services develop capabilities that are both proactive and flexible, which grow alongside the threat environment. Every step from the scope definition to continual improvement activity works toward preserving the confidentiality, integrity, and availability of information assets.

When combined with associated frameworks (such as ISO 9001 Quality Management and ISO 22301 Business Continuity) it provides a risk-based, unified approach to operational excellence. Finally, a well-planned and ever-evolving ISMS helps by changing information security from an after-the-fact operation to tactical manager of business achievement.

12. References

- Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).
- Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).
- (Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.
- Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).